

Data Processing Addendum

Effective 6 October 2026 · The Loyalty Loop

1. Purpose and definitions

This Data Processing Addendum ("DPA") applies where a business ("Merchant", the "Controller") uses The Loyalty Loop ("Provider", the "Processor") to process personal data of its loyalty programme members ("Customer Personal Data") on the Merchant's behalf. It forms part of the Merchant Agreement and reflects the requirements of Article 28 of the UK GDPR. If this DPA conflicts with the Merchant Agreement about the processing of Customer Personal Data, this DPA prevails.

"Data Protection Laws" means the UK GDPR, the Data Protection Act 2018 and the Privacy and Electronic Communications Regulations 2003, as amended or replaced, and, where applicable to the processing, the EU GDPR. "UK GDPR", "personal data", "processing", "controller", "processor", "data subject" and "personal data breach" have the meanings given in the UK GDPR. "Subprocessor" means a third party that we engage to process Customer Personal Data. "Restricted Transfer" means a transfer of personal data to a country or recipient outside the UK that is restricted by Chapter V of the UK GDPR.

2. Duration and scope

This DPA remains in effect for as long as we process Customer Personal Data, even after the Merchant Agreement ends, and covers the provision of the Merchant Services described in the Merchant Agreement. Processing continues while the Merchant Agreement is in effect, and for a reasonable period afterwards as needed to return or delete Customer Personal Data under sections 4 and 10.

3. Nature, purpose and details of processing

Where acting on a Merchant's instructions, we record member loyalty activity, eligible spend, reward progress, redemptions and refund adjustments; provide authorised staff access; and send requested communications subject to member preferences. Optional card-linked transaction matching helps reconcile the Merchant's programme. The Loyalty Loop separately acts as controller for its account administration, platform security and optional card-linking relationship with shoppers, as described in the Privacy Notice.

- Data subjects: the Merchant's loyalty members, and the Merchant's staff users.
- Categories of personal data: names and contact information, loyalty identifiers, shop membership, purchase amount, currency and time, merchant and transaction references, refund and clearing status, progress, redemption records, and submitted messages or reviews. Provider card identifiers and limited card metadata support matching in the platform; this does not give merchants access to full card numbers or security codes.
- Special categories of data: none. The Merchant must not put sensitive categories of data (such as health, racial or ethnic origin, or government identification numbers) into the Merchant Services.
- Frequency: ongoing, as initiated by the Merchant's use of the Merchant Services.
- Duration and retention: for the term of the Merchant Agreement, then as set out in section 10.

4. Processor obligations

- Process Customer Personal Data only on the Merchant's documented instructions, as set out in this DPA, the Merchant Agreement and the configuration and features the Merchant selects, unless the law requires otherwise (in which case we will tell the Merchant first, unless the law prohibits it). We will tell the Merchant if we believe an instruction breaches Data Protection Laws.
- Ensure that personnel authorised to process Customer Personal Data are bound by confidentiality obligations.
- Implement the technical and organisational security measures in Annex 1, which we may update provided the overall level of protection is not materially reduced.
- Notify the Merchant without undue delay after becoming aware of a personal data breach affecting Customer Personal Data, with the information we have available and the steps taken to mitigate it, and cooperate reasonably with the Merchant's investigation. Our notice is not an admission of fault.
- Taking into account the nature of the processing, assist the Merchant, where reasonably possible and technically feasible, in responding to data subject requests and in meeting its obligations for security, breach notification, data protection impact assessments and consultation with regulators. If we receive a data subject request about the Merchant's data, we will pass it to the Merchant and advise the person to contact the Merchant.
- At the Merchant's choice, delete or return Customer Personal Data at the end of the Merchant Services, as set out in section 10, except where retention is required by law.
- Make available information reasonably necessary to demonstrate compliance with this DPA, and allow for audits as described in section 7.
- Not use Customer Personal Data to train, fine-tune or improve any artificial-intelligence or machine-learning model, and prohibit our Subprocessors from doing so, unless the Merchant authorises it in writing.

5. Merchant responsibilities

- The Merchant is the controller and is responsible for having a valid legal basis for its instructions, giving its members the notices required by Articles 12 to 14 of the UK GDPR, and obtaining any consents needed for its own use of the data (including marketing).
- The Merchant is responsible for how its staff use the Merchant Services, for keeping its account credentials and staff PINs secure, and for the accuracy of the data it enters.
- The Merchant must not put sensitive categories of data into the Merchant Services.

6. Subprocessors

The Merchant gives general authorisation for The Loyalty Loop to engage Subprocessors to provide the Merchant Services. The Subprocessors in use at the date of this DPA are listed in Annex 2. We will enter into a written contract with each Subprocessor that gives data protection obligations not less protective than those in this DPA, and we remain responsible for their performance of those obligations.

We will give the Merchant reasonable notice (including by email or in the dashboard) before adding or replacing a Subprocessor. If the Merchant objects on reasonable grounds relating to data protection within 15 days of the notice, we will work with the Merchant in good faith to resolve the objection. If we cannot, the Merchant may end the Merchant Agreement under section 5 of that agreement.

7. Audits

On reasonable written request, we will provide the information reasonably necessary to demonstrate our compliance with this DPA and will allow and contribute to audits, including inspections, by the Merchant or an independent auditor it appoints, up to once a year (or more often where required by law or by a regulator). Audits are subject to reasonable notice, normal business hours, confidentiality and minimal disruption to our service, and the auditor must not be a competitor of ours.

8. International transfers

We will only make a Restricted Transfer of Customer Personal Data where a lawful transfer mechanism is in place, such as an adequacy decision or approved data-bridge arrangement, the UK International Data Transfer Agreement, or the UK Addendum to the EU standard contractual clauses. To the extent the Merchant is a controller located in the UK, it authorises these transfers to the Subprocessors in Annex 2.

9. Card-linking providers

Fidel API and payment networks participate in enrolment and transaction matching. Their role for each processing activity must follow the applicable provider agreement; this DPA does not label all Fidel or network processing as processing solely on the Merchant's instructions. Where a provider acts as our Subprocessor for Customer Personal Data, section 6 applies. Independently controlled processing is subject to that provider's own notice and lawful basis. Merchant instructions cannot override a shopper's card-linking withdrawal.

10. Return and deletion

When the Merchant Services end, we will stop processing Customer Personal Data except to store it and return, delete or anonymise it. On written request made within 30 days after the end date, we will at the Merchant's choice return a copy of Customer Personal Data by a secure method and then delete it, or delete it. If no instruction is given in that period, we will delete or anonymise the data within a reasonable time afterwards. We may keep data where the law requires it, only for as long and for the purpose the law requires, and keep it confidential and secure.

Assist with correction and deletion requests, including identifying disputed transactions. Account-level card removal and deletion are handled under the Privacy Notice; ending one shop membership is not a request to delete the shopper's entire platform account.

11. Liability and general

Each party's liability under this DPA is subject to the limitations and exclusions of liability in the Merchant Agreement, except that nothing limits liability that cannot be limited by law or rights data subjects have under Data Protection Laws. We may vary this DPA on written notice only as necessary to stay compliant with Data Protection Laws, provided the variation does not materially reduce the protection of Customer Personal Data. This DPA is governed by the laws of England and Wales.

Data protection questions about this DPA can be sent to help@the-loyalty-loop.com.

Annex 1: Security measures

- Information security responsibility: named responsibility for the development, implementation and maintenance of our security programme, with periodic review of risks.
- Data segregation and access control: logical separation of data between merchants, access controls enforced at the database level, role-based permissions (including for staff scanning and redemption actions), least-privilege access and unique credentials.
- Encryption and credentials: encryption of data in transit over public networks and at rest on our hosting providers, and secure hashed storage of credentials such as staff PINs.
- Logging and monitoring: logging of user access and system activity, error monitoring and alerting.
- Operational controls: secure configuration and maintenance of systems, tracked change management, and vulnerability and patch management, including dependency updates.
- Incident response: procedures to investigate, contain and notify in line with section 4 of this DPA.
- Physical and environmental security: provided by our hosting and cloud providers in secured data centres.
- Continuity: backup and recovery arrangements designed to restore the service after foreseeable incidents.

Annex 2: Subprocessors

- Supabase: cloud database, authentication and file storage.
- Vercel: web hosting and delivery.
- Resend: transactional email delivery.
- Fidel API: optional card enrolment and transaction matching, to the extent it acts as our Subprocessor (see section 9).
- Expo and the mobile platform notification services (Apple and Google): push notification delivery.
- Google: maps and location-based features.
- Sentry: technical error monitoring, configured not to receive personal data such as email addresses.

Optional AI-assisted analytics or research features are provided only where the Merchant actively enables them. The Loyalty Loop's own website analytics provider (PostHog) processes website usage data for us as controller and does not process Customer Personal Data on a Merchant's behalf. We will update this list before changes take effect, as described in section 6.

About this document

Adapted from open legal templates published by General Legal, PC (<https://github.com/General-Legal/legal-templates>, CC0 1.0) and tailored to the law of England and Wales and to how The Loyalty Loop works. The original templates are general reference material only and are not legal advice; General Legal has not reviewed this version.